RDP BRUTE FORCE ATTACK SIMULATION & DETECTION

SOC Analyst Lab project

Lab Date: 14 Mach 2026

Report Date: 20 March 2026

Project by: Mohammad Mubashir

Environment: VirtualBox Lab

Attacker: Kali Linux – 192.168.1.18

Victim: Windows - 192.168.1.16

Tools: Kali Linux, Hydra/Crowbar, Windows 11 Event Viewer

1. INTRODUCTION

1.1 Project Objective

The main objective of this project is to simulate a real-world RDP brute force attack and perform detection using Windows Event log. This project demonstrates both Red Team attackers and Blue Team defense perspective is a controlled lab environment.

1.2 Scope

This Project Covers:

- Enabling RDP on Window 11
- Creating a weak password user
- Simulating brute force attack using Hydra/Crowbar
- Analyzing failed login attempt (Event ID 4625)
- Identifying successful RDP login (Event ID 4624, Logon type 10)
- Documenting indicators of compromise (IOCs)

1.3 Tools Used

Tools	Purpose
Hydra/Crowbar	Brute Force
Windows 11	Victim machine
Event Viewer	Log analysis
Kali Linux	Attacker machine

2. LAB Setup

2.1 Lab Environment

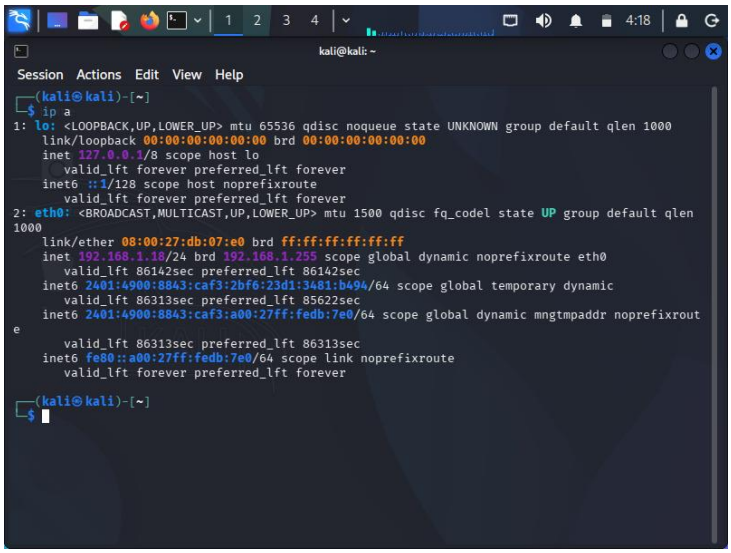
Machine	Operating System	IP Address	Role
Attacker	Kali Linux	192.168.1.18	Brute Force attack
Victim	Windows 11	192.168.1.16	RDP Target

2.2 Network setup

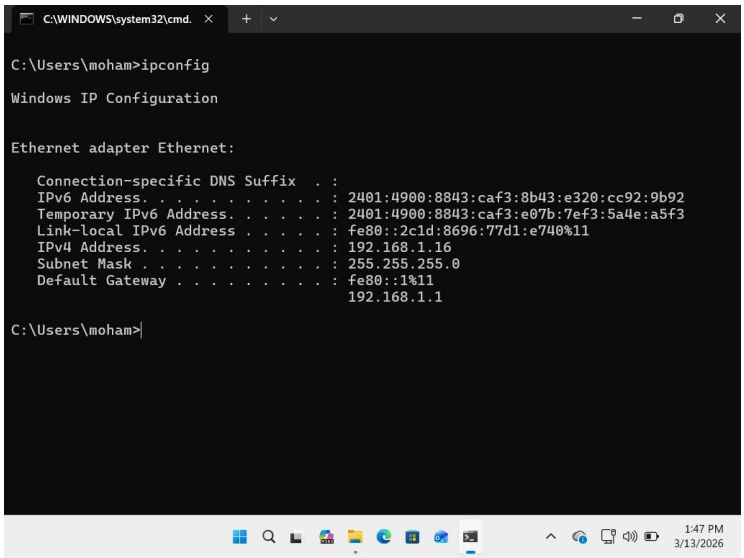
Both machines are connected through a private virtual network using VirtualBox Bridge Adapter. This ensures an isolated lab environment without external interference.

2.3 IP Verification

Screenshot 1: Kali IP Address

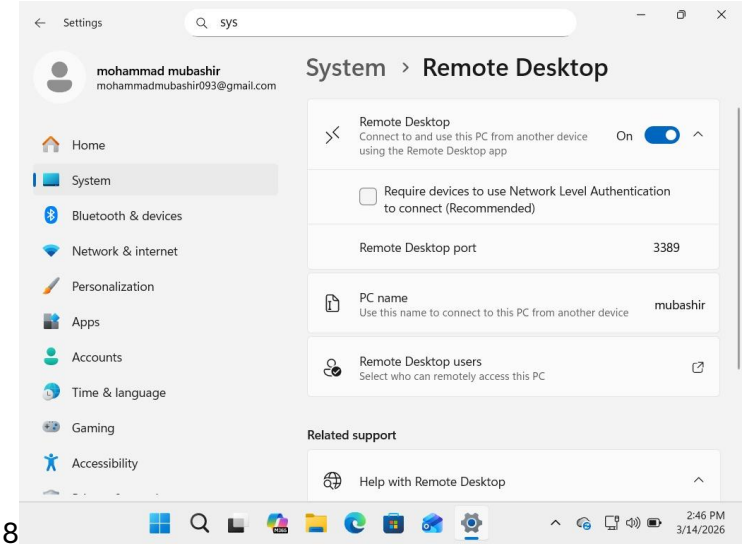


Screenshot 2: Windows IP Address



2.4 RDP Configuration

Screenshot 3: RDP Connection



3. ATTACK PHASE (RED TEAM)

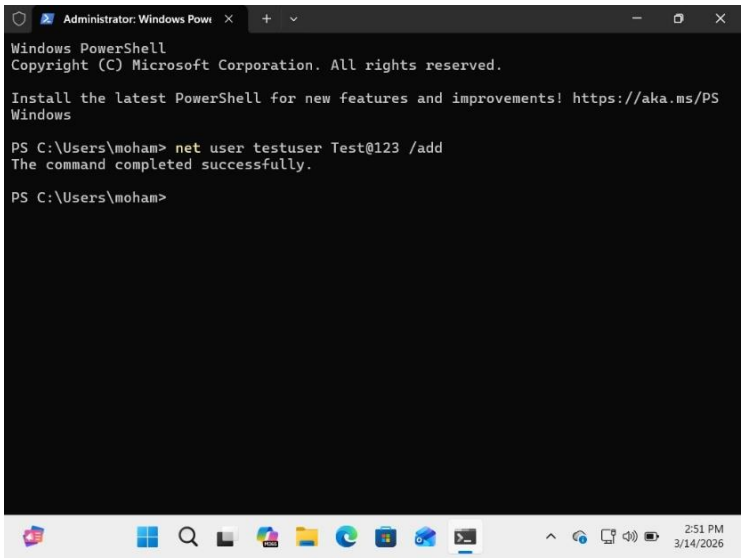
3.1 Target User Creation (Windows 11)

Command:

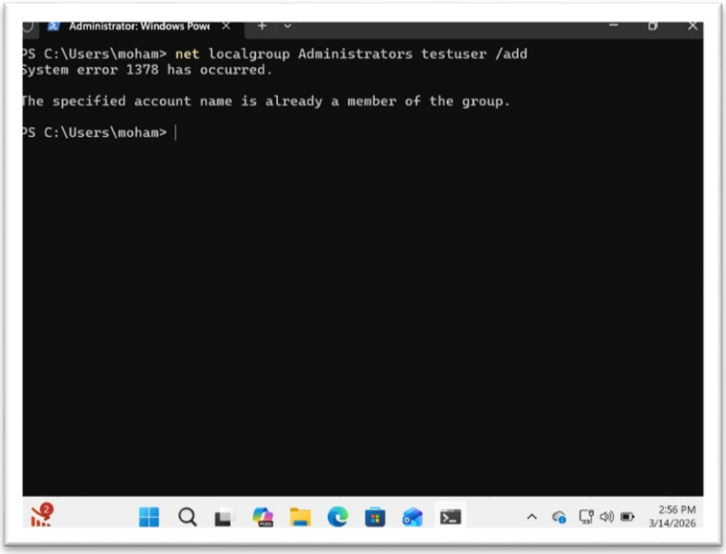
Net user testuser Test@123 /add

Net localgroup Administrators testuser /add

Screenshot 4: User creation successfully



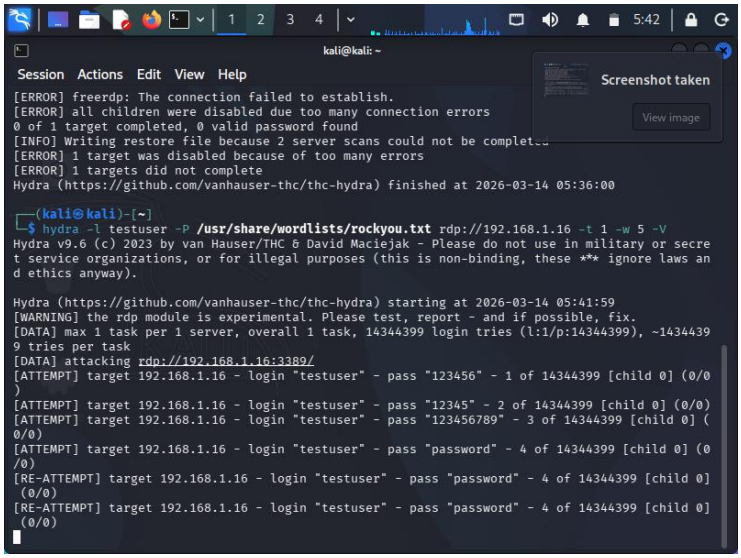
Screenshot 5: A user add to administrator group



3.2 Brute force attempt with Hydra

Command: hydra -l testuser -P /usr/share/wordlists/rockyou.txt rdp://192.168.1.16 -t 1 -w 5 -V

Screenshot 6: Hydra attack in process



3.3 Issue encounter with Hydra

During the Hydra attack, the following error was observed:
[ERROR] freeRDP: The connection failed to establish.
[ERROR] all children were disabled due too many connection errors

Reason:
Hydra's RDP module is experimental and unstable. It failed to maintain

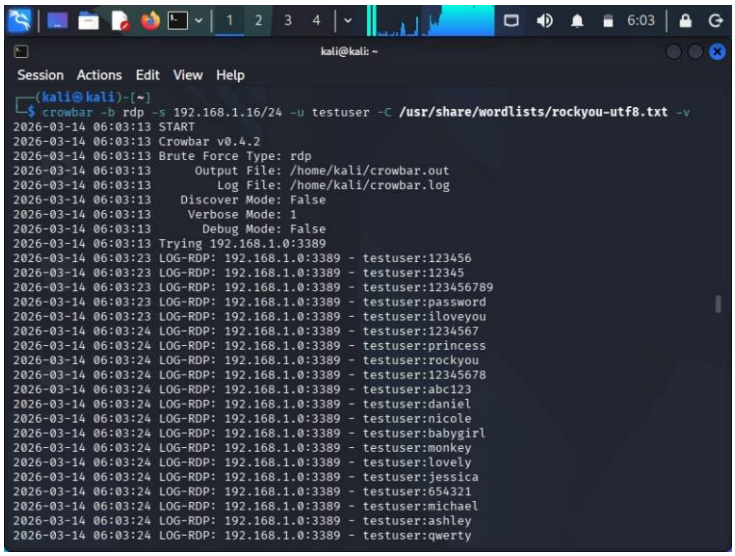
consistent connections with the Windows RDP service, causing the attack to terminate prematurely.

3.4 Alternative Tool – Crowbar

Since Hydra was not working reliably, Crowbar was used as an alternative.
Crowbar is specifically designed for RDP brute force attacks and is more stable.

Command:
sudo apt install crowbar -y
crowbar -b rdp -s 192.168.1.16 -u testuser -C /usr/share/wordlists/rockyou-utf8.txt -v

Screenshot 7: Crowbar attack in process



3.5 Wordlist issue with crowbar

While running Crowbar, an encoding error was encountered:
Error: 'utf-8' codec can't decode byte 0xf1 in position 5079973: invalid continuation byte

sudo iconv -f ISO-8859-1 -t UTF-8 /usr/share/wordlists/rockyou.txt -o /usr/share/wordlists/rockyou-utf8.txt

crowbar -b rdp -s 192.168.1.16 -u testuser -C /usr/share/wordlists/rockyou-utf8.txt -v

3.6 Attack observation

Due to the large size of the rockyou.txt wordlist (~14 million passwords),

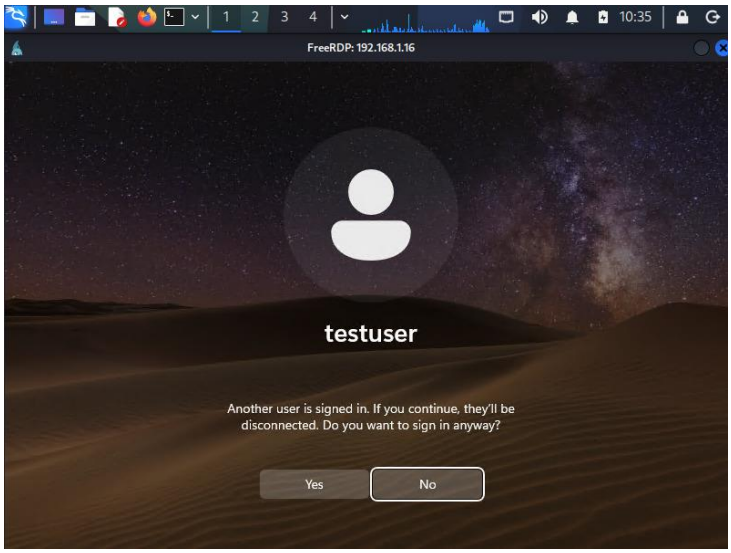
the complete brute force process would take several hours. Successfully simulated an RDP brute force environment, confirmed active authentication attempts, and manually verified credential access to demonstrate detection capability

- RDP service was accessible and responsive
- Target username 'testuser' was valid
- Authentication attempts were being processed

3.7 Manual login verification

xfreerdp /v:192.168.1.16 /u:testuser /p:Test@123

Screenshot 8: Successful xfree RDP login



Manual login confirmed that the credentials "testuser:Test@123" are valid and RDP is functioning correctly.

4. DETECTION PHASE (BLUE TEAM)

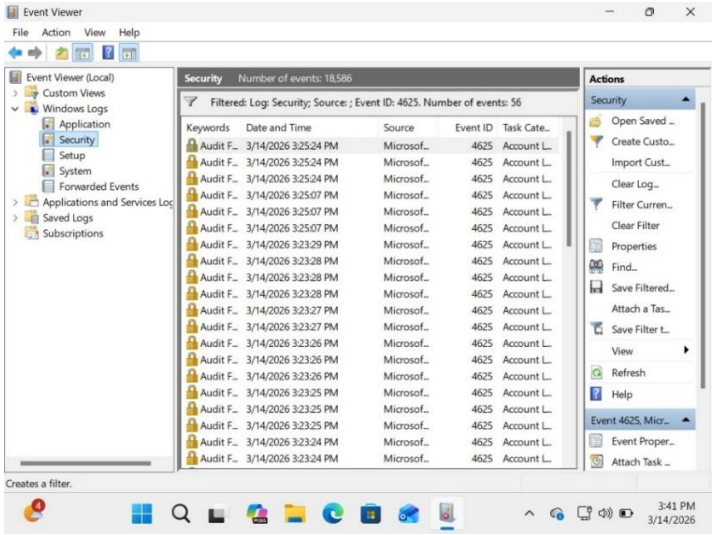
4.1 Windows Event Log Analysis

Windows Event Logs were analyzed to detect the brute force attack. The following Event IDs were monitored to identify both failed and successful login attempts.

4.2 Failed login attempt (Event ID 4625)

Filter Applied:
Event ID: 4625

Screenshot 9: Multiple failed login attempt

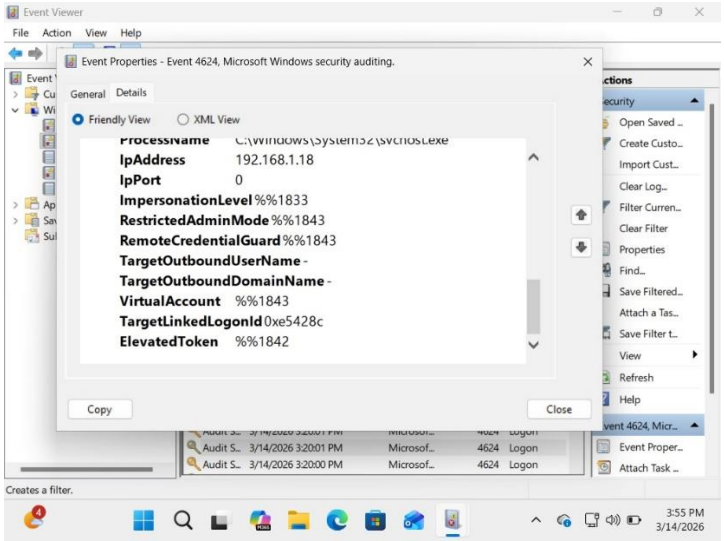


4.3 Key Observation From Failed Login Attempts

- Multiple Event ID 4625 entries confirm active brute force attempt
- Logon Type 10 indicates all attempts were RDP-based
- Status Code 0xc000006d confirms wrong password attempts
- Time stamps show multiple attempts within short time span

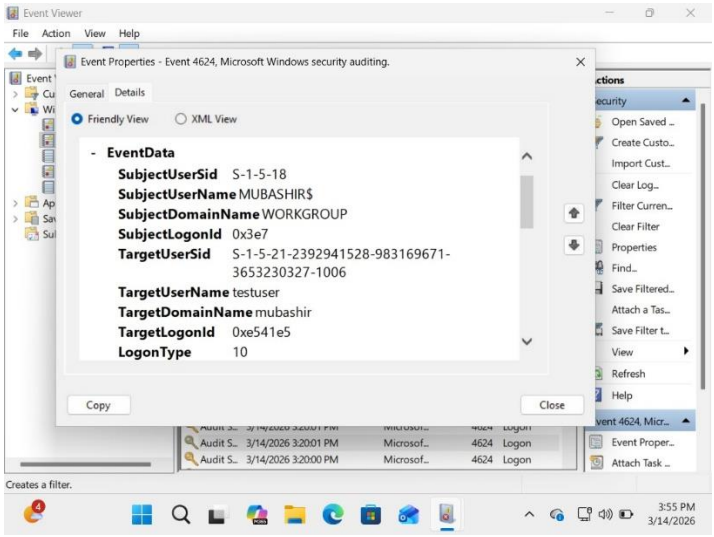
4.4 Successfully login (Event ID 4624)
Filter Applied: Event ID: 4624

Screenshot 10: Event ID 4624 successfully RDP login



4.5 Logon Type 10 confirmation

Screenshot 11: Logon Type 10 – Successful RDP



5. INDICATORS OF COMPROMISE (IOCs)

5.1 Definition

Indicators of Compromise (IOCs) are forensic artifacts observed on a system network that indicate a potential security breach or malicious activity. These artifact help Security Analyst investigation and response to cyber threats.

5.2 IOC identified in this project

IOC NO.	Category	Indicator	Description
IOC 01	Network Based	Source IP: 192.168.1.18	Attacker machine IP identified in RDP logins attempts
IOC 02	Host Based	Logon Type 10	All attempts were Remotes Desktop (RDP)
IOC 03	Host Based	Event ID 4625	Multiple failed RDP login attempts
IOC 04	Host Based	Event ID 4624	Successful RDP login after multiple failures

5.3 IOC Severity Classification

IOC NO	Severity	Justification
IOC 01	Critical	Attacker Source IP identified in RDP logins attempts
IOC 02	High	RDP logon type 10 confirms remote access attempt
IOC 03	High	Multiple failed logins indicate active brute force attack
IOC 04	Critical	Successful login confirms compromise

5.4 Importance of IOCs in SOC Operations

In a Security Operations Center (SOC), IOCs are used to:

- Detect ongoing or past intrusions
- Correlate events across multiple data sources
- Trigger alerts for immediate response
- Improve threat hunting and forensic analysis
- Enhance security monitoring rules and use cases

6. CONCLUSION

6.1 Project Summary

This project successfully demonstrated a complete RDP brute force attack simulation followed by detection and analysis from a defender's perspective. The entire attack lifecycle was executed in an isolated VirtualBox lab environment using Kali Linux as the attacker machine and Windows 11 as the victim.

6.2 Key Achievements

- Successfully enabled RDP on Windows 11
- Created test user with weak password
- Attempted brute force using Hydra and Crowbar
- Analyzed Event ID 4625 (failed logins)
- Identified successful login via Event ID 4624
- Confirmed Logon Type 10 for RDP
- Documented 4 Key IOCs for SOC monitoring

6.3 Learning Outcomes

Penetration Testing: How attackers use Hydra/Crowbar for RDP brute force
Windows Security: Importance of strong passwords and account lockout policies
Log Analysis: How to detect brute force using Event ID 4625 and 4624
IOC Identification: How to document forensic evidence for incident response
Tool Troubleshooting: Handling tool errors (Hydra unstable, wordlist encoding issues

6.4 Challenges Faced & Solutions

Challenge	Solution
Hydra RDP module unstable	**Switched to Crowbar (more stable for RDP)**
Wordlist encoding error	**Converted rockyou.txt to UTF-8 using iconv**
Large wordlist time-consuming	**Used manual login to verify credentials**
Event logs overwhelming	**Applied filtered (Event ID 4625, 4624, Logon Type 10)**

6.5 Future Scope

This project can be extended and improved in the following ways:

1. Account Lockout Policy Implementation
Configuring Windows account lockout policy to automatically lock a user account after a defined number of failed login attempts. This would significantly reduce the risk of successful brute force attacks in a real environment.

2. RDP Port Change & Network Level Authentication
Changing the default RDP port from 3389 to a custom port, and enabling Network Level Authentication (NLA). This adds an extra layer of protection before any login attempt is processed.

3. Firewall Rules & IP Whitelisting
Implementing strict firewall rules to allow RDP access only from trusted IP addresses. This would block unauthorized sources like the attacker machine used in this lab.

4. Automated Alert Creation
Creating automated Windows Task Scheduler alerts triggered by multiple Event ID 4625 occurrences within a short time window. This simulates a basic real-world SOC alerting mechanism without requiring a full SIEM setup.

5. Multi-User Brute Force Simulation
Extending this lab by creating multiple target user accounts and running simultaneous brute force attempts. This would generate a larger volume of logs and provide more realistic detection practice.

6. Log Forwarding to Central Server

Configuring Windows Event Log forwarding to a centralized log collection server. This demonstrates how enterprise environments aggregate logs from multiple machines for unified monitoring.

7. GitHub Repository

https://github.com/Mubashir-soc-01/SOC-Project

8. LinkedIn post

https://www.linkedin.com/in/mohammad-mubashir-b729643b7/

Project #2 complete:
"RDP Brute Force Attack Simulation & Detection".

- Simulated brute force attack using Hydra + Crowbar
- Detected failed (4625) and successful (4624) RDP logins
- Learned real SOC log analysis & IOC documentation

GitHub: [https://github.com/Mubashir-soc-01/SOC-Project]

THANK YOU

Project by: Mohammad Mubashir

Date: 20 March 2026